Botium Toys

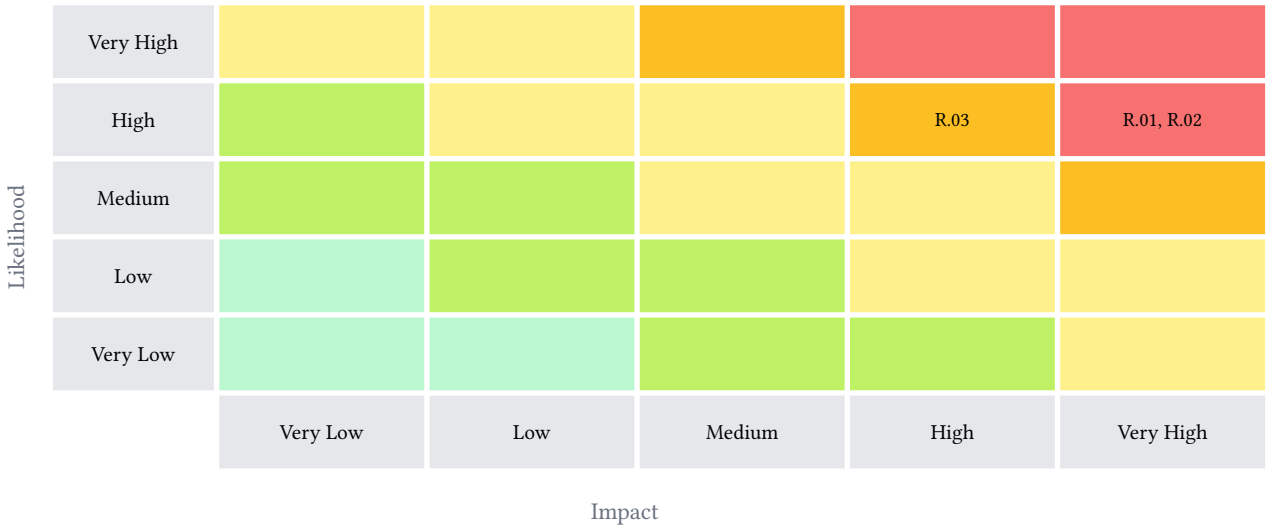
Risk assessment — 1.0

Domain	Botium Toys
Perimeter	-
Risk matrix	critical 5x5
Status	-
Authors	-
Reviewers	-
ETA / Due	- — -

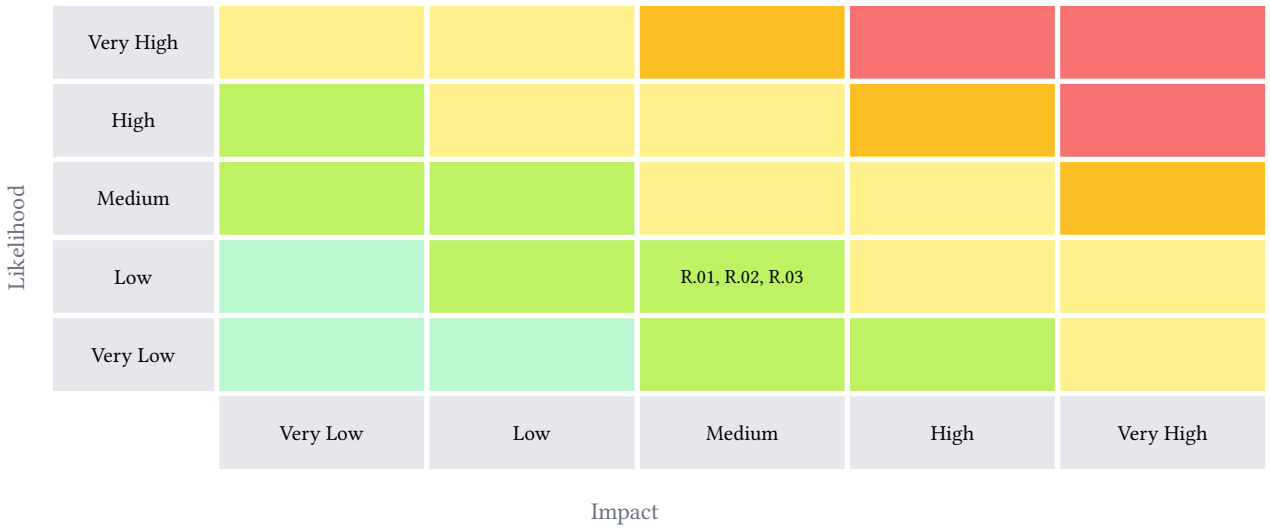
Generated at 2026-10-14 18:28:41 UTC
Document ID `00981ae2-a7a8-426f-b919-6482b904b128`

Risk matrix

Current risk



Residual risk



Scenario summary

Ref.	Name	Description	Current	Residual	Treatment
R.01	Unrestricted employee access to cardholder data and customer PII	All employees currently have access to all data in the system, including cardholder data and customer PII/SPII, with no access controls enforcing least privilege or separation of duties. This creates risk of unauthorized data access, misuse, or exposure, whether accidental or malicious, with potential consequences under PCI DSS Requirement 7	Very High	Low	Open
R.02	Unencrypted cardholder data at rest	Credit card information is stored without encryption, in violation of PCI DSS Requirements 3 and 4, which require the primary account number to be rendered unreadable (via encryption or tokenization) and strong cryptography for cardholder data in transit. Exposure of this data carries significant regulatory, financial, and reputational risk.	Very High	Low	Open
R.03	Weak Password Complexity Requirement	Current password policy does not meet minimum security standards for password complexity (length, character variety) or require multifactor authentication. This increases the likelihood of credential compromise, which combined with the lack of least-privilege access controls, could grant an attacker broad access to cardholder data.	High	Low	Open

Risk scenarios

3 scenarios.

R.01 — Unrestricted employee access to cardholder data and customer PII

Description	All employees currently have access to all data in the system, including cardholder data and customer PII/SPII, with no access controls enforcing least privilege or separation of duties. This creates risk of unauthorized data access, misuse, or exposure, whether accidental or malicious, with potential consequences under PCI DSS Requirement 7
Assets	E-commerce Platform/Payment Systems
Threats	Inadequate Cybersecurity Governance and Accountability
Current level	Very High
Extra controls	Access Control Policy
Residual level	Low
Strength of knowledge	--
Treatment	Open

R.02 — Unencrypted cardholder data at rest

Description	Credit card information is stored without encryption, in violation of PCI DSS Requirements 3 and 4, which require the primary account number to be rendered unreadable (via encryption or tokenization) and strong cryptography for cardholder data in transit. Exposure of this data carries significant regulatory, financial, and reputational risk.
Assets	E-commerce Platform/Payment Systems, Internal Database
Threats	Inadequate Cybersecurity Governance and Accountability
Current level	Very High
Extra controls	Cardholder Data Encryption
Residual level	Low
Strength of knowledge	High
Treatment	Open

R.03 — Weak Password Complexity Requirement

Description	Current password policy does not meet minimum security standards for password complexity (length, character variety) or require multifactor authentication. This increases the likelihood of credential compromise, which combined with the lack of least-privilege access controls, could grant an attacker broad access to cardholder data.
Assets	E-commerce Platform/Payment Systems, Internal Database
Threats	Credential Theft via Phishing or Social Engineering
Current level	High
Extra controls	Password and Authentication Policy
Residual level	Low
Strength of knowledge	--
Treatment	Open